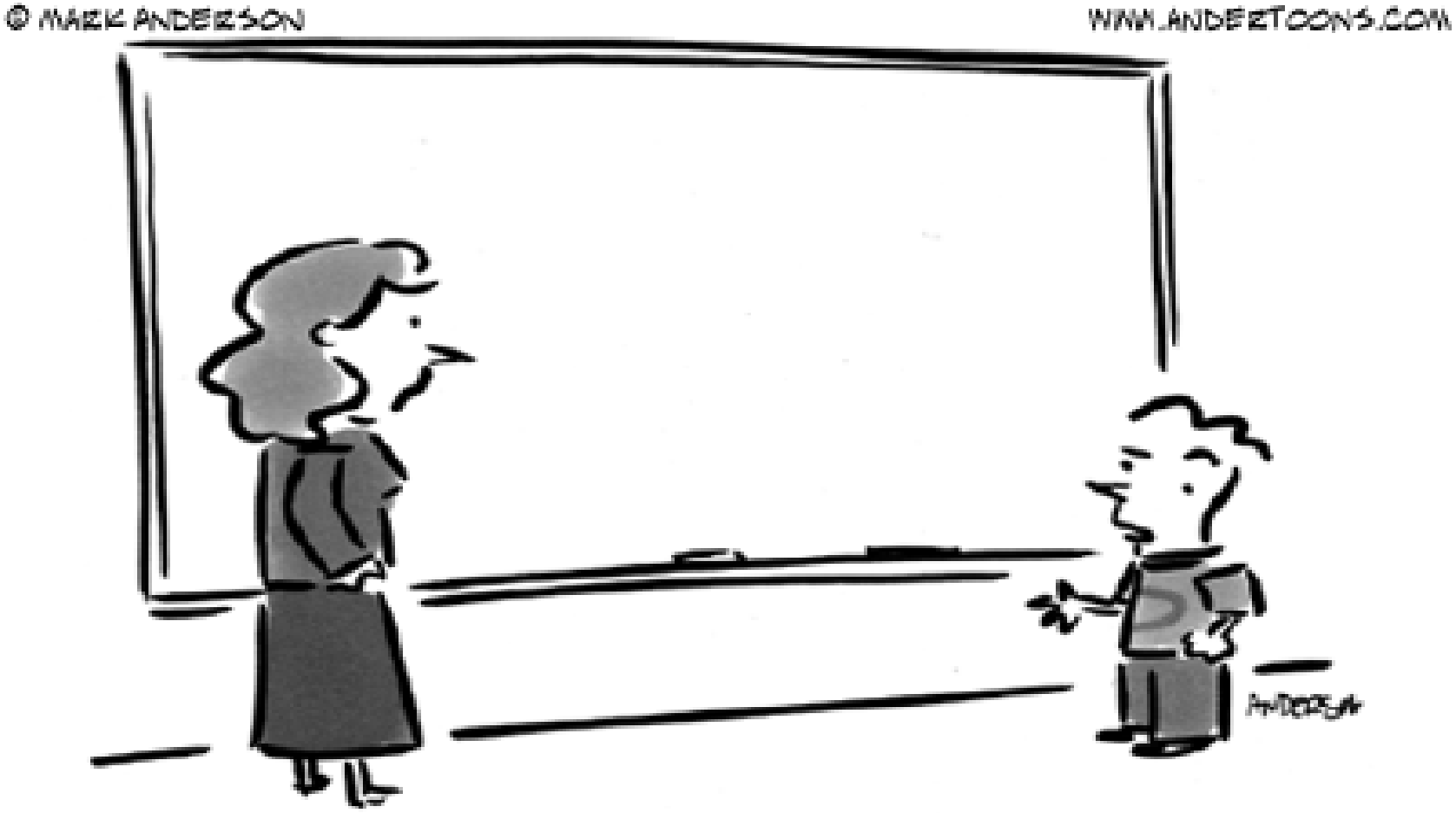
GENERAL DATA PROTECTION REGULATION



Dr. Balraj K Sidhu
IIT Kharagpur



"Before I write my name on the board, I'll need to know how you're planning to use that data."

Source: Mark Anderson, Andertoooons

Right to Privacy-I

- Data Collection and Use
- **Big data analytics** involves deploying techniques and tools in the form of structuring data, performing statistical modeling, and creating visualizations that could transform otherwise incomprehensible datasets into meaningful information.
- The threat to privacy looms large as the entity performing the analysis could learn more about a person life, they may be able to find connection between the online identities to real-world people, find out a person's habits or personal information



Right to Privacy-II

- ***Big Brother Watch v. UK*** (2018, ECtHR)

- The case was filed by NGO named Big Brother in 2013 post Snowden revelations, it challenged surveillance conducted by the Government Communications Headquarters (GCHQ) in the following instances:

  i. Bulk interception of communications (TEMPORA program);

  ii. Intelligence sharing and receipt in collaboration with the PRISM and Upstream programs run by the NSA and

  iii. Obtaining of communications data from service providers

- Court held that the **UK's bulk interception regime violated the right to privacy for its lack of sufficient oversight and safeguards**

Data Protection Law Models

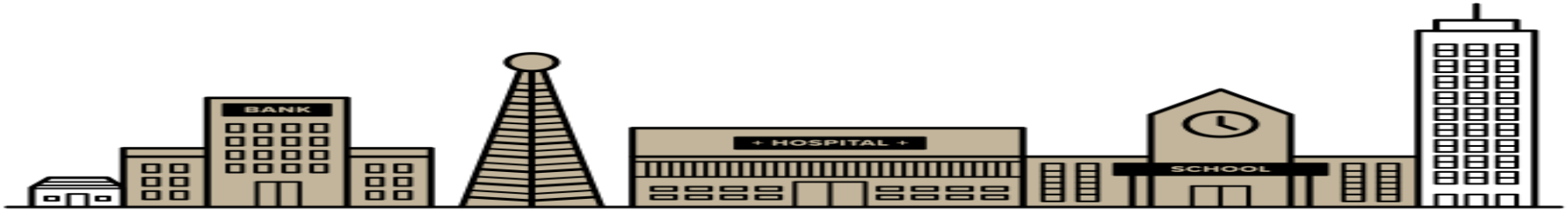




Data protection law systems are usually seen as a dichotomy between the United States of America and the European Union.



In the **sectoral approach** which is followed in the US data protection is regulated on a sector-to-sector basis. Different industries have different regulation, and some areas are not regulated at all. Public and private sectors are regulated by different statutes.

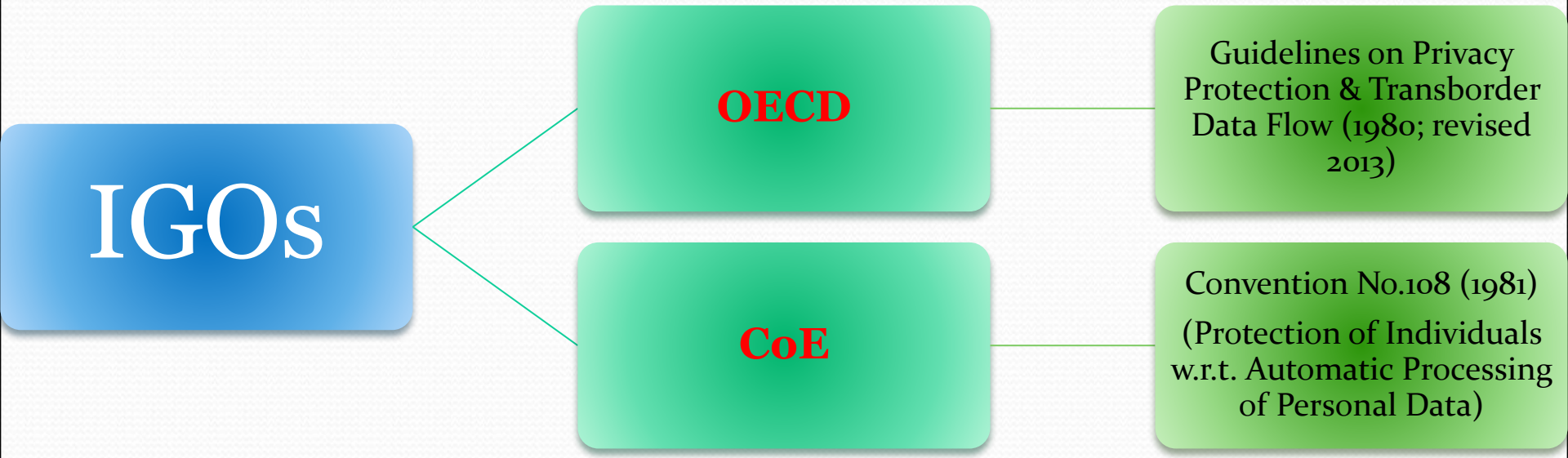


On the other hand, the **omnibus approach** of the EU means that a single law protects personal data in all industries and most contexts. A single comprehensive data protection statute can cover the private and public sector both.

Meaning of Data Protection Law

- Data protection legislation applies where personal data (including sensitive personal data) relating to an identifiable individual (data subject) is subjected to certain forms of processing.
- The nature and extent of processing will be determined by a data controller, although the actual processing may be carried out by data processor operating under an outsourcing or similar contract with the data controller.

International Data Protection Initiatives



OECD: FIRST INTERNATIONAL GUIDELINES ABOUT PRIVACY

- In 1980, the Organisation for Economic Co-operation and Development (**OECD**) adopts its **Guidelines on the Protection of Privacy and Transborder Flows of Personal Data**.
- The Preface notes:
  - *'Privacy protection laws have been introduced, or will be introduced shortly, in approximately one half of OECD Member countries (Austria, Canada, Denmark, France, Germany, Luxembourg, Norway, Sweden and the United States have passed legislation. Belgium, Iceland, the Netherlands, Spain and Switzerland have prepared draft bills) to prevent what are considered to be violations of fundamental human rights, such as the unlawful storage of personal data, the storage of inaccurate personal data, or the abuse or unauthorised disclosure of such data.'*
  - *On the other hand, there is a danger that disparities in national legislations could hamper the free flow of personal data across frontiers; these flows have greatly increased in recent years and are bound to grow further with the widespread introduction of new computer and communications technology. Restrictions on these flows could cause serious disruption in important sectors of the economy, such as banking and insurance.'*

OECD Guidelines on Privacy Protection & Transborder Data Flow (1980; revised 2013)

- Are not legally binding on OECD member states
- Covers both public and private sectors
- Manual and electronic processing of personal data
- Enunciated core data privacy principles





Article 8 - Right to respect for private and family life

1 Everyone has the right to respect for his private and family life, his home and his correspondence.

COUNCIL OF EUROPE

CONSEIL DE L'EUROPE

European Treaty Series - No. 108

Convention for the Protection of Individuals with regard to Automatic Processing of Personal Data

Strasbourg, 28.I.1981

Preamble

The member States of the Council of Europe, signatory hereto,

Considering that the aim of the Council of Europe is to achieve greater unity between its members, based in particular on respect for the rule of law, as well as human rights and fundamental freedoms;

Considering that it is desirable to extend the safeguards for everyone's rights and fundamental freedoms, and in particular the right to the respect for privacy, taking account of the increasing flow across frontiers of personal data undergoing automatic processing;

Reaffirming at the same time their commitment to freedom of information regardless of frontiers;

Recognising that it is necessary to reconcile the fundamental values of the respect for privacy and the free flow of information between peoples,

Convention No.108 (1981)

- First and only legally binding international instrument with worldwide significance on data protection.
- Undergone revision in May 2018 - *Modernized Convention for the Protection of Individuals with Regard to the Processing of Personal Data*
- Requires contracting states to incorporate its principles into their domestic legislation
- Chapter II sets out basic **principles of data processing**

Making of the European Union

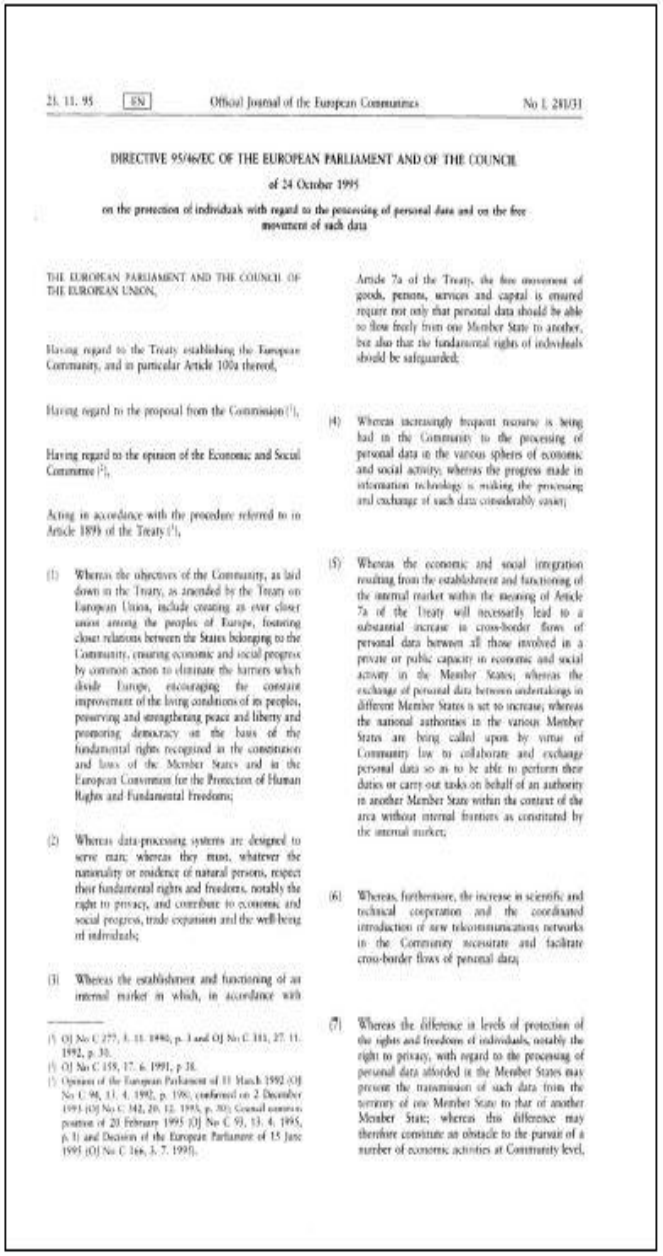
TREATY OF MAASTRICHT

- Signed in 1992, entered into force 1993.
- Established 'pillar structure'.
  - 1st pillar: European Communities, covering the single market.
  - 2nd pillar: Common Foreign and Security Policy.
  - 3rd pillar: Justice and Home Affairs, as a follow up the Schengen developments.
- Eventually, the Treaty of Amsterdam (signed 1997, entered into force 1999) created the Area of Freedom, Security and Justice & incorporated borders, visa, immigration and asylum policies into the Community method.

TREATY OF LISBON

- Signed in 2007, entered into force 2009.
- Key changes for EU data protection:
  - the EU Charter of Fundamental Rights becomes legally binding;
  - collapse of the 'pillar structure';
  - Article 16 TFEU.
  - changes affecting the role of the European Parliament in international agreements.

1995



23. 11. 95 EN Official Journal of the European Communities No L 281/31

DIRECTIVE 95/46/EC OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL

of 24 October 1995

on the protection of individuals with regard to the processing of personal data and on the free movement of such data

THE EUROPEAN PARLIAMENT AND THE COUNCIL OF THE EUROPEAN UNION,

Having regard to the Treaty establishing the European Community, and in particular Article 100a thereof,

Having regard to the proposal from the Commission (1),

Having regard to the opinion of the Economic and Social Committee (2),

Acting in accordance with the procedure referred to in Article 189b of the Treaty (3),

(1) Whereas the objectives of the Community, as laid down in the Treaty, as amended by the Treaty on European Union, include creating an ever closer union among the peoples of Europe, fostering closer relations between the States belonging to the Community, ensuring economic and social progress by common action to eliminate the barriers which divide Europe, encouraging the constant improvement of the living conditions of its peoples, preserving and strengthening peace and liberty and promoting democracy on the basis of the fundamental rights recognized in the constitution and laws of the Member States and in the European Convention for the Protection of Human Rights and Fundamental Freedoms;

(2) Whereas data-processing systems are designed to serve man; whereas they must, whatever the nationality or residence of natural persons, respect their fundamental rights and freedoms, notably the right to privacy, and contribute to economic and social progress, trade expansion and the well-being of individuals;

(3) Whereas the establishment and functioning of an internal market in which, in accordance with Article 7a of the Treaty, the free movement of goods, persons, services and capital is ensured require not only that personal data should be able to flow freely from one Member State to another, but also that the fundamental rights of individuals should be safeguarded;

(4) Whereas increasingly frequent recourse is being had in the Community to the processing of personal data in the various spheres of economic and social activity; whereas the progress made in information technology is making the processing and exchange of such data considerably easier;

(5) Whereas the economic and social integration resulting from the establishment and functioning of the internal market within the meaning of Article 7a of the Treaty will necessarily lead to a substantial increase in cross-border flows of personal data between all those involved in a private or public capacity in economic and social activity in the Member States; whereas the exchange of personal data between undertakings in different Member States is set to increase; whereas the national authorities in the various Member States are being called upon by virtue of Community law to collaborate and exchange personal data so as to be able to perform their duties or carry out tasks on behalf of an authority in another Member State within the context of the area without internal frontiers as constituted by the internal market;

(6) Whereas, furthermore, the increase in scientific and technical cooperation and the coordinated introduction of new telecommunications networks in the Community necessitate and facilitate cross-border flows of personal data;

(7) Whereas the difference in levels of protection of the rights and freedoms of individuals, notably the right to privacy, with regard to the processing of personal data afforded in the Member States may prevent the transmission of such data from the territory of one Member State to that of another Member State; whereas this difference may therefore constitute an obstacle to the pursuit of a number of economic activities at Community level,

(1) OJ No C 277, 5. 11. 1990, p. 3 and OJ No C 311, 27. 11. 1992, p. 30.
(2) OJ No C 159, 17. 6. 1991, p. 38.
(3) Opinion of the European Parliament of 11 March 1992 (OJ No C 94, 13. 4. 1992, p. 198), confirmed on 2 December 1993 (OJ No C 342, 20. 12. 1993, p. 30); Council common position of 20 February 1995 (OJ No C 93, 13. 4. 1995, p. 1) and Decision of the European Parliament of 15 June 1995 (OJ No C 166, 3. 7. 1995).

Directive 95/46/EC of the European Parliament and of the Council of 24 October 1995 on the protection of individuals with regard to the processing of personal data and on the free movement of such data

PRIMARY LAW

- Charter of Fundamental Rights of the EU
  - Article 7
  - Article 8

- Treaty on the Functioning of the EU
  - Article 16

2000

CHARTER OF FUNDAMENTAL RIGHTS OF THE EUROPEAN UNION

(2000/C 364/01)

Article 7

Respect for private and family life

Everyone has the right to respect for his or her private and family life, home and communications.

Article 8

Protection of personal data

1. Everyone has the right to the protection of personal data concerning him or her.

2. Such data must be processed fairly for specified purposes and on the basis of the consent of the person concerned or some other legitimate basis laid down by law. Everyone has the right of access to data which has been collected concerning him or her, and the right to have it rectified.

3. Compliance with these rules shall be subject to control by an independent authority.

ART. 16 TFEU

Article 16

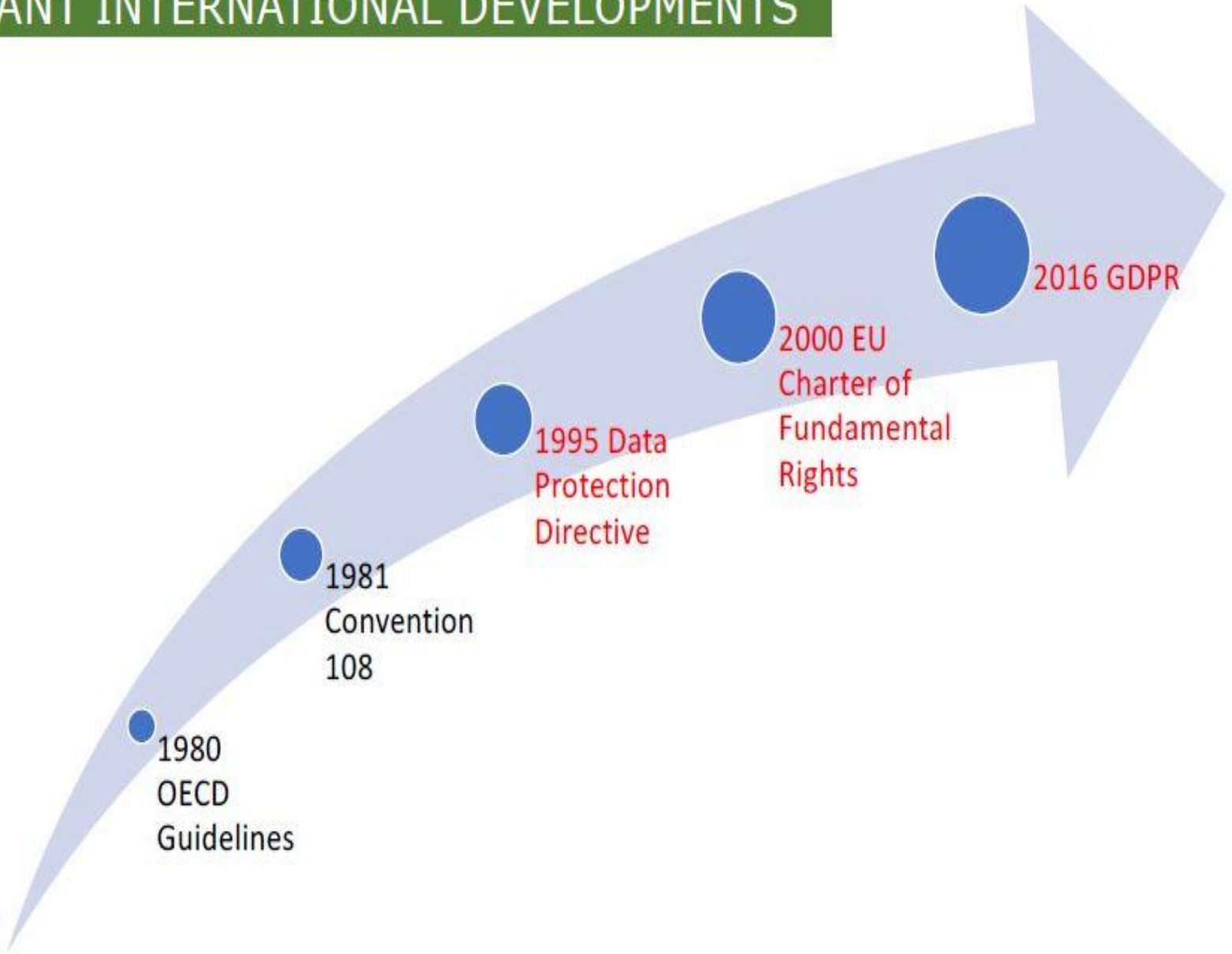
(ex Article 286 TEC)

1. Everyone has the right to the protection of personal data concerning them.

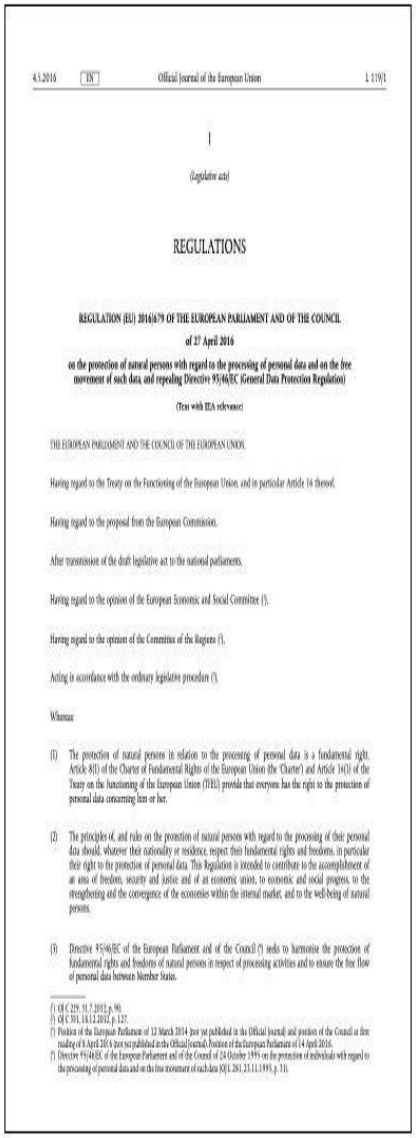
2. The European Parliament and the Council, acting in accordance with the ordinary legislative procedure, shall lay down the rules relating to the protection of individuals with regard to the processing of personal data by Union institutions, bodies, offices and agencies, and by the Member States when carrying out activities which fall within the scope of Union law, and the rules relating to the free movement of such data. Compliance with these rules shall be subject to the control of independent authorities.

The rules adopted on the basis of this Article shall be without prejudice to the specific rules laid down in Article 39 of the Treaty on European Union.

IMPORTANT INTERNATIONAL DEVELOPMENTS



2016



4.5.2016 EN Official Journal of the European Union L 119/1

I

(Legislative acts)

REGULATIONS

REGULATION (EU) 2016/679 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL

of 27 April 2016

on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation)

(Text with EEA relevance)

THE EUROPEAN PARLIAMENT AND THE COUNCIL OF THE EUROPEAN UNION,

Having regard to the Treaty on the Functioning of the European Union, and in particular Article 16 thereof,

Having regard to the proposal from the European Commission,

After transmission of the draft legislative act to the national parliaments,

Having regard to the opinion of the European Economic and Social Committee (1),

Having regard to the opinion of the Committee of the Regions (2),

Acting in accordance with the ordinary legislative procedure (3),

Whereas:

(1) The protection of natural persons in relation to the processing of personal data is a fundamental right. Article 8(1) of the Charter of Fundamental Rights of the European Union (the 'Charter') and Article 16(1) of the Treaty on the functioning of the European Union (TFEU) provide that everyone has the right to the protection of personal data concerning him or her.

(2) The principles of, and rules on the protection of natural persons with regard to the processing of their personal data should, whatever their nationality or residence, respect their fundamental rights and freedoms, in particular their right to the protection of personal data. This Regulation is intended to contribute to the accomplishment of an area of freedom, security and justice and of an economic union, to economic and social progress, to the strengthening and the convergence of the economies within the internal market, and to the well-being of natural persons.

(3) Directive 95/46/EC of the European Parliament and of the Council (4) seeks to harmonise the protection of fundamental rights and freedoms of natural persons in respect of processing activities and to ensure the free flow of personal data between Member States.

(1) OJ C 229, 31.7.2012, p. 90.
(2) OJ C 391, 18.12.2012, p. 127.
(3) Position of the European Parliament of 12 March 2014 (not yet published in the Official Journal) and position of the Council at first reading of 8 April 2016 (not yet published in the Official Journal). Position of the European Parliament of 14 April 2016.
(4) Directive 95/46/EC of the European Parliament and of the Council of 24 October 1995 on the protection of individuals with regard to the processing of personal data and on the free movement of such data (OJ L 281, 23.11.1995, p. 31).

Directive 95/46/EC of the European Parliament and of the Council of 24 October 1995 on the protection of individuals with regard to the processing of personal data and on the free movement of such data

Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation)

APPLICABLE WHERE?

- EU Member States: Austria, Belgium, Bulgaria, Croatia, Cyprus, Czech Republic, Denmark, Estonia, Finland, France, Germany, Greece, Hungary, Ireland, Italy, Latvia, Lithuania, Luxembourg, Malta, the Netherlands, Poland, Portugal, Romania, Slovakia, Slovenia, Spain, and Sweden.
- European Economic Area (EEA) countries: Iceland, Lichtenstein, and Norway.

GDPR: Article 1

- Art 1 - harmonize data protection laws across Europe; To strengthen and unify data protection for individuals within the EU.

ART. 1 GDPR

Article 1

Subject-matter and objectives

1. This Regulation lays down rules relating to the protection of natural persons with regard to the processing of personal data and rules relating to the free movement of personal data.

2. This Regulation protects fundamental rights and freedoms of natural persons and in particular their right to the protection of personal data.

3. The free movement of personal data within the Union shall be neither restricted nor prohibited for reasons connected with the protection of natural persons with regard to the processing of personal data.

GDPR: Article 1

- Art 1 - harmonize data protection laws across Europe; To strengthen and unify data protection for individuals within the EU.

RECITAL 9 GDPR

(9) The objectives and principles of Directive 95/46/EC remain sound, but it has not prevented fragmentation in the implementation of data protection across the Union, legal uncertainty or a widespread public perception that there are significant risks to the protection of natural persons, in particular with regard to online activity. Differences in the level of protection of the rights and freedoms of natural persons, in particular the right to the protection of personal data, with regard to the processing of personal data in the Member States may prevent the free flow of personal data throughout the Union. Those differences may therefore constitute an obstacle to the pursuit of economic activities at the level of the Union, distort competition and impede authorities in the discharge of their responsibilities under Union law. Such a difference in levels of protection is due to the existence of differences in the implementation and application of Directive 95/46/EC.

When does GDPR Apply? Material Scope

ART. 2 GDPR

Article 2

Material scope

1. This Regulation applies to the processing of personal data wholly or partly by automated means and to the processing other than by automated means of personal data which form part of a filing system or are intended to form part of a filing system.

2. This Regulation does not apply to the processing of personal data:

(a) in the course of an activity which falls outside the scope of Union law;

(b) by the Member States when carrying out activities which fall within the scope of Chapter 2 of Title V of the TEU;

(c) by a natural person in the course of a purely personal or household activity;

(d) by competent authorities for the purposes of the prevention, investigation, detection or prosecution of criminal offences or the execution of criminal penalties, including the safeguarding against and the prevention of threats to public security.

3. For the processing of personal data by the Union institutions, bodies, offices and agencies, Regulation (EC) No 45/2001 applies. Regulation (EC) No 45/2001 and other Union legal acts applicable to such processing of personal data shall be adapted to the principles and rules of this Regulation in accordance with Article 98.

4. This Regulation shall be without prejudice to the application of Directive 2000/31/EC, in particular of the liability rules of intermediary service providers in Articles 12 to 15 of that Directive.

Jehovah's Witnesses v. Finland (2018)

- Took notes whilst undertaking door-to-door visits to people they did not know.
- The personal data involved was names and addresses along with information about religious beliefs and family circumstances.
- The Court held the **data was covered by data protection law even in this hardcopy format.** EU data protection law applies to **manual data processing** where data processed in this way forms part of a filing system.
- The court also ruled that a religious community can be a **data controller, jointly with its members** who engage in preaching, of the processing of personal data carried out by the members in the context of door-to-door preaching organized, coordinated and encouraged by that community.

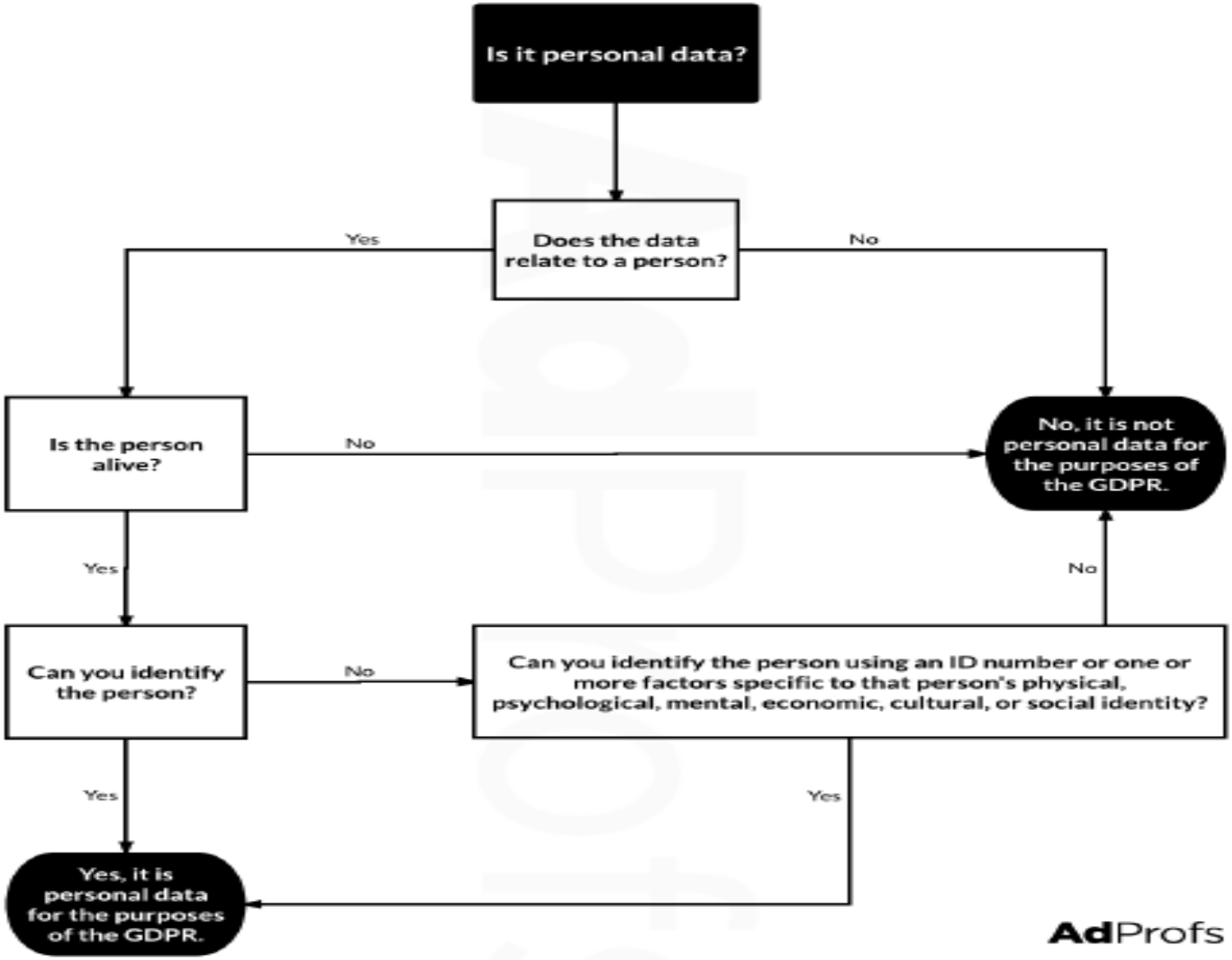
Concept of Personal Data-I

- **Article 4 (1) GDPR**: 'personal data' means any information relating to an identified or identifiable natural person ('data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person

Concept of Personal Data-II

- Personal data only includes information **relating** to **natural persons** who:
  - can be **identified or who are identifiable**, **directly** from the information in question; or
  - can be **indirectly** identified from that information in combination with other information.
  - Dynamic IP addresses: *Breyer v. Bundesrepublik Deutschland (*CJEU, 2016)- yes it is personal data
- Anonymized data: not subject to GDPR
- Pseudonymisation: yes subject to GDPR
- Information about deceased persons? Whether GDPR is applicable or not? (Recital 27)

Concept of Personal Data-III



Concept of Personal Data-III

CASE C-434/16 NOWAK

ECLI:EU:C:2017:994

- Judgment of the Court (Grand Chamber) of 20 December 2017.
- Request has been made in proceedings between Mr Peter Nowak and the Data Protection Commissioner (Ireland) concerning the latter's refusal to give Mr Nowak access to a corrected script of an examination at which he was a candidate, on the ground that the information contained therein did not constitute personal data.

42 As regards the comments of an examiner with respect to the candidate's answers, it is clear that they, no less than the answers submitted by the candidate at the examination, constitute information relating to that candidate.

43 The content of those comments reflects the opinion or the assessment of the examiner of the individual performance of the candidate in the examination, particularly of his or her knowledge and competences in the field concerned. The purpose of those comments is, moreover, precisely to record the evaluation by the examiner of the candidate's performance, and those comments are liable to have effects for the candidate, as stated in paragraph 39 of this judgment.

44 The finding that the comments of the examiner with respect to the answers submitted by the candidate at the examination constitute information which, by reason of its content, purpose or effect, is linked to that candidate is not called into question by the fact that those comments also constitute information relating to the examiner.

45 The same information may relate to a number of individuals and may constitute for each of them, provided that those persons are identified or identifiable, personal data, within the meaning of Article 2(a) of Directive 95/46.

Data Processing

- **Article 4 (2) GDPR**

- Processing covers a wide range of operations performed on personal data, including by manual or automated means.

- Includes the **collection, recording, organisation, structuring, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination** or otherwise making available, **alignment or combination, restriction, erasure or destruction** of personal data.

When does not GDPR Apply? Material Scope

ART. 2 GDPR

Article 2

Material scope

1. This Regulation applies to the processing of personal data wholly or partly by automated means and to the processing other than by automated means of personal data which form part of a filing system or are intended to form part of a filing system.

2. This Regulation does not apply to the processing of personal data:

(a) in the course of an activity which falls outside the scope of Union law;

(b) by the Member States when carrying out activities which fall within the scope of Chapter 2 of Title V of the TEU;

(c) by a natural person in the course of a purely personal or household activity;

(d) by competent authorities for the purposes of the prevention, investigation, detection or prosecution of criminal offences or the execution of criminal penalties, including the safeguarding against and the prevention of threats to public security.

3. For the processing of personal data by the Union institutions, bodies, offices and agencies, Regulation (EC) No 45/2001 applies. Regulation (EC) No 45/2001 and other Union legal acts applicable to such processing of personal data shall be adapted to the principles and rules of this Regulation in accordance with Article 98.

4. This Regulation shall be without prejudice to the application of Directive 2000/31/EC, in particular of the liability rules of intermediary service providers in Articles 12 to 15 of that Directive.

When does not GDPR Apply? Material Scope

RECITAL 16 GDPR

(16) This Regulation does not apply to issues of protection of fundamental rights and freedoms or the free flow of personal data related to activities which fall outside the scope of Union law, such as activities concerning national security. This Regulation does not apply to the processing of personal data by the Member States when carrying out activities in relation to the common foreign and security policy of the Union.

RECITAL 18 GDPR

(18) This Regulation does not apply to the processing of personal data by a natural person in the course of a purely personal or household activity and thus with no connection to a professional or commercial activity. Personal or household activities could include correspondence and the holding of addresses, or social networking and online activity undertaken within the context of such activities. However, this Regulation applies to controllers or processors which provide the means for processing personal data for such personal or household activities.

Where does GDPR Apply? Territorial Scope

ART. 3 GDPR

Article 3

Territorial scope

1. This Regulation applies to the processing of personal data in the context of the activities of an establishment of a controller or a processor in the Union, regardless of whether the processing takes place in the Union or not.

2. This Regulation applies to the processing of personal data of data subjects who are in the Union by a controller or processor not established in the Union, where the processing activities are related to:

(a) the offering of goods or services, irrespective of whether a payment of the data subject is required, to such data subjects in the Union; or

(b) the monitoring of their behaviour as far as their behaviour takes place within the Union.

3. This Regulation applies to the processing of personal data by a controller not established in the Union, but in a place where Member State law applies by virtue of public international law.

DEFINITION OF 'CONTROLLER'

Art. 4(7) GDPR

'controller' means the natural or legal person, public authority, agency or other body which, alone or jointly with others, determines the purposes and means of the processing of personal data; where the purposes and means of such processing are determined by Union or Member State law, the controller or the specific criteria for its nomination may be provided for by Union or Member State law.

DEFINITION OF 'PROCESSOR'

Art. 4(8) GDPR

'processor' means a natural or legal person, public authority, agency or other body which processes personal data on behalf of the controller.

Joint Controllership (Art 26)

- **CJEU - C-40/17 - Fashion ID**
- Fashion ID, an online retailer clothing company, embedded the 'Like' social plug-in from Facebook on its website. When a visitor visited the website, whether they clicked on the plug-in or not, their personal data was transmitted to Facebook Ireland without the user's knowledge or consent of this whether or not they had user accounts with Facebook.
- **Two questions – (i) Can suit be brought up by a NGO (ii) Fashion ID is controller - YES**
- ECJ concludes that **Fashion ID is a joint controller together with Facebook**.
- Fashion ID embedded the plug-in to optimize the publicity of its goods and make them more visible to a visitor. As such, it consented to the terms of using the plug-in to benefit from the commercial advantage of increased publicity of its goods, well aware that the plug-in enabled transmission of personal data to Facebook Ireland. Facebook Ireland also had a commercial benefit of processing such personal data.

Where does GDPR Apply? Territorial Scope

RECITAL 22 GDPR

(22) Any processing of personal data in the context of the activities of an establishment of a controller or a processor in the Union should be carried out in accordance with this Regulation, regardless of whether the processing itself takes place within the Union. Establishment implies the effective and real exercise of activity through stable arrangements. The legal form of such arrangements, whether through a branch or a subsidiary with a legal personality, is not the determining factor in that respect.

Example 1: A car manufacturing company with headquarters in the US has a fully-owned branch office located in Brussels overseeing all its operations in Europe, including marketing and advertisement.

The Belgian branch can be considered to be a stable arrangement, which exercises real and effective activities in light of the nature of the economic activity carried out by the car manufacturing company. As such, the Belgian branch could therefore be considered as an establishment in the Union, within the meaning of the GDPR.

Where does GDPR Apply? Territorial Scope

Example 4: A French company has developed a car-sharing application exclusively addressed to customers in Morocco, Algeria and Tunisia. The service is only available in those three countries but all personal data processing activities are carried out by the data controller in France.

While the collection of personal data takes place in non-EU countries, the subsequent processing of personal data in this case is carried out in the context of the activities of an establishment of a data controller in the Union. Therefore, even though processing relates to personal data of data subjects who are not in the Union, the provisions of the GDPR will apply to the processing carried out by the French company, as per Article 3(1).

Where does GDPR Apply? Territorial Scope

Example 3: A hotel and resort chain in South Africa offers package deals through its website, available in English, German, French and Spanish. The company does not have any office, representation or stable arrangement in the EU.

Where does GDPR Apply? Territorial Scope

RECITAL 23 GDPR

(23) In order to ensure that natural persons are not deprived of the protection to which they are entitled under this Regulation, the processing of personal data of data subjects who are in the Union by a controller or a processor not established in the Union should be subject to this Regulation where the processing activities are related to offering goods or services to such data subjects irrespective of whether connected to a payment. In order to determine whether such a controller or processor is offering goods or services to data subjects who are in the Union, it should be ascertained whether it is apparent that the controller or processor envisages offering services to data subjects in one or more Member States in the Union. Whereas the mere accessibility of the controller's, processor's or an intermediary's website in the Union, of an email address or of other contact details, or the use of a language generally used in the third country where the controller is established, is insufficient to ascertain such intention, factors such as the use of a language or a currency generally used in one or more Member States with the possibility of ordering goods and services in that other language, or the mentioning of customers or users who are in the Union, may make it apparent that the controller envisages offering goods or services to data subjects in the Union.

When does GDPR Apply? Territorial Scope

Example 10: A U.S. citizen is travelling through Europe during his holidays. While in Europe, he downloads and uses a news app that is offered by a U.S. company. The app is exclusively directed at the U.S. market, evident by the app terms of use and the indication of US Dollar as the sole currency available for payment. The collection of the U.S. tourist's personal data via the app by the U.S. company is not subject to the GDPR.

Example 11: A bank in Taiwan has customers that are residing in Taiwan but hold German citizenship. The bank is active only in Taiwan; its activities are not directed at the EU market. The bank's processing of the personal data of its German customers is not subject to the GDPR.

When does GDPR Apply? Territorial Scope

Example 14: A website, based and managed in Turkey, offers services for the creation, editing, printing and shipping of personalised family photo albums. The website is available in English, French, Dutch and German and payments can be made in Euros. The website indicates that photo albums can only be delivered by post mail in France, Benelux countries and Germany.

In this case, it is clear that the creation, editing and printing of personalised family photo albums constitute a service within the meaning of EU law. The fact that the website is available in four languages of the EU and that photo albums can be delivered by post in six EU Member States demonstrates that there is an intention on the part of the Turkish website to offer its services to individuals in the Union.

As a consequence, it is clear that the processing carried out by the Turkish website, as a data controller, relates to the offering of a service to data subjects in the Union and is therefore subject to the obligations and provisions of the GDPR, as per its Article 3(2)(a).

Data Protection Principles

CHAPTER II

PRINCIPLES

- Article 5: Principles relating to processing of personal data
- Article 6: Lawfulness of processing
- Article 7: Conditions for consent
- Article 8: Conditions applicable to child's consent in relation to information society services
- Article 9: Processing of special categories of personal data
- Article 10: Processing of personal data relating to criminal convictions and offences
- Article 11: Processing which does not require identification

Data Protection Principles

ART. 5 GDPR

Article 5

Principles relating to processing of personal data

1. Personal data shall be:

(a) processed lawfully, fairly and in a transparent manner in relation to the data subject ('lawfulness, fairness and transparency');

(b) collected for specified, explicit and legitimate purposes and not further processed in a manner that is incompatible with those purposes; further processing for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes shall, in accordance with Article 89(1), not be considered to be incompatible with the initial purposes ('purpose limitation');

(c) adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed ('data minimisation');

(d) accurate and, where necessary, kept up to date; every reasonable step must be taken to ensure that personal data that are inaccurate, having regard to the purposes for which they are processed, are erased or rectified without delay ('accuracy');

(e) kept in a form which permits identification of data subjects for no longer than is necessary for the purposes for which the personal data are processed; personal data may be stored for longer periods insofar as the personal data will be processed solely for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes in accordance with Article 89(1) subject to implementation of the appropriate technical and organisational measures required by this Regulation in order to safeguard the rights and freedoms of the data subject ('storage limitation');

(f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measures ('integrity and confidentiality').

2. The controller shall be responsible for, and be able to demonstrate compliance with, paragraph 1 ('accountability').

Data Protection Principles

ART. 5(1)(A) GDPR

(a) processed lawfully, fairly and in a transparent manner in relation to the data subject ('lawfulness, fairness and transparency');

- Lawfulness: cf. Art. 6 GDPR.
- Fairness: any processing of personal data must be 'fair'.
- Transparency:
  - cf. Recital 39 GDPR: '*The principle of transparency requires that any information and communication relating to the processing of those personal data be easily accessible and easy to understand, and that clear and plain language be used.*'
  - cf. Art. 12 GDPR.

Data Protection Principles

ART. 6(1) GDPR

Article 6

Lawfulness of processing

1. Processing shall be lawful only if and to the extent that at least one of the following applies:

(a) the data subject has given consent to the processing of his or her personal data for one or more specific purposes;

(b) processing is necessary for the performance of a contract to which the data subject is party or in order to take steps at the request of the data subject prior to entering into a contract;

(c) processing is necessary for compliance with a legal obligation to which the controller is subject;

(d) processing is necessary in order to protect the vital interests of the data subject or of another natural person;

(e) processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller;

(f) processing is necessary for the purposes of the legitimate interests pursued by the controller or by a third party, except where such interests are overridden by the interests or fundamental rights and freedoms of the data subject which require protection of personal data, in particular where the data subject is a child.

Point (f) of the first subparagraph shall not apply to processing carried out by public authorities in the performance of their tasks.

Lawful Processing under GDPR

ABOUT ART. 6(1)(A) GDPR

- Art. 6(1)(a): (Processing shall be lawful if and to the extent that) *'the data subject has **given consent** to the processing of his or her personal data for one or more specific purposes'.*
- See also:
  - Art. 4 GDPR: Definition of consent
  - Art. 7 GDPR Conditions of consent
  - Art. 8 GDPR: Conditions of child's consent in relation to information society services

DEFINITION OF CONSENT

Art. 4(11) GDPR

'consent' of the data subject means any freely given, specific, informed and unambiguous indication of the data subject's wishes by which he or she, by a statement or by a clear affirmative action, signifies agreement to the processing of personal data relating to him or her;

Lawful Processing under GDPR

ART. 7 GDPR

Article 7

Conditions for consent

1. Where processing is based on consent, the controller shall be able to demonstrate that the data subject has consented to processing of his or her personal data.

2. If the data subject's consent is given in the context of a written declaration which also concerns other matters, the request for consent shall be presented in a manner which is clearly distinguishable from the other matters, in an intelligible and easily accessible form, using clear and plain language. Any part of such a declaration which constitutes an infringement of this Regulation shall not be binding.

3. The data subject shall have the right to withdraw his or her consent at any time. The withdrawal of consent shall not affect the lawfulness of processing based on consent before its withdrawal. Prior to giving consent, the data subject shall be informed thereof. It shall be as easy to withdraw as to give consent.

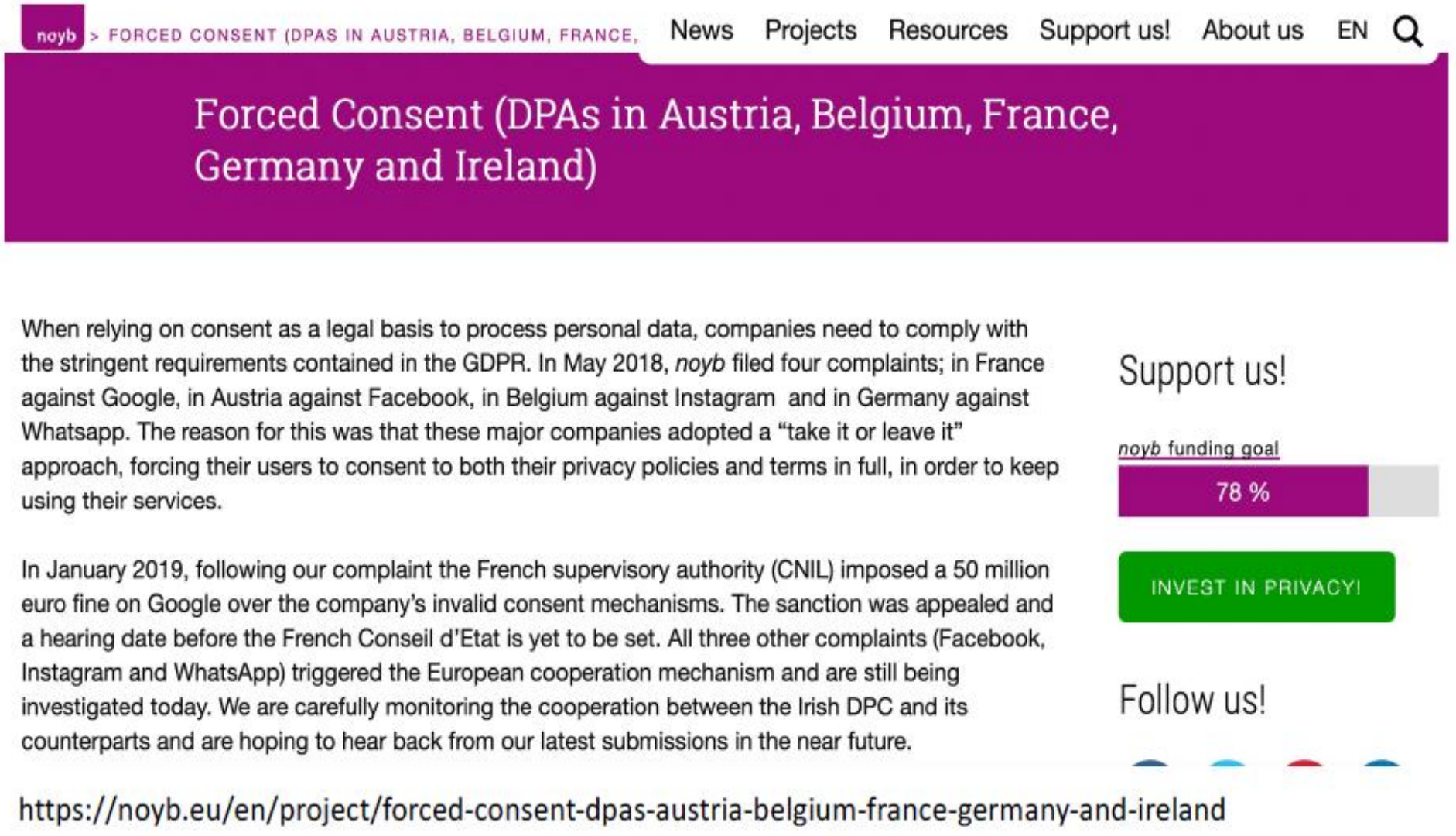
4. When assessing whether consent is freely given, utmost account shall be taken of whether, *inter alia*, the performance of a contract, including the provision of a service, is conditional on consent to the processing of personal data that is not necessary for the performance of that contract.

Lawful Processing under GDPR

RECITAL (32)

(32) Consent should be given by a clear affirmative act establishing a freely given, specific, informed and unambiguous indication of the data subject's agreement to the processing of personal data relating to him or her, such as by a written statement, including by electronic means, or an oral statement. This could include ticking a box when visiting an internet website, choosing technical settings for information society services or another statement or conduct which clearly indicates in this context the data subject's acceptance of the proposed processing of his or her personal data. Silence, pre-ticked boxes or inactivity should not therefore constitute consent. Consent should cover all processing activities carried out for the same purpose or purposes. When the processing has multiple purposes, consent should be given for all of them. If the data subject's consent is to be given following a request by electronic means, the request must be clear, concise and not unnecessarily disruptive to the use of the service for which it is provided.

Lawful Processing under GDPR



https://noyb.eu/en/project/forced-consent-dpas-austria-belgium-france-germany-and-ireland

Data Protection Principles – Purpose Limitation

ART. 5(1)(B) GDPR

(b) collected for specified, explicit and legitimate purposes and not further processed in a manner that is incompatible with those purposes; further processing for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes shall, in accordance with Article 89(1), not be considered to be incompatible with the initial purposes ('purpose limitation');

- Data must be collected for **specified**, **explicit** and **legitimate** purposes.
- Data **cannot further processed in a manner incompatible** with the original purposes (see: Art. 6(4) & Recital 50 GDPR for the criteria to take into account to assess 'compatibility'):
  - However, it is possible to ground that processing on another ground (e.g. consent).
- If further processing takes place based on its compatibility with the original purposes, no further ground is necessary.

Data Protection Principles – Purpose Limitation

ART. 6(4) GDPR

4. Where the processing for a purpose other than that for which the personal data have been collected is not based on the data subject's consent or on a Union or Member State law which constitutes a necessary and proportionate measure in a democratic society to safeguard the objectives referred to in Article 23(1), the controller shall, in order to ascertain whether processing for another purpose is compatible with the purpose for which the personal data are initially collected, take into account, inter alia:

(a) any link between the purposes for which the personal data have been collected and the purposes of the intended further processing;

(b) the context in which the personal data have been collected, in particular regarding the relationship between data subjects and the controller;

(c) the nature of the personal data, in particular whether special categories of personal data are processed, pursuant to Article 9, or whether personal data related to criminal convictions and offences are processed, pursuant to Article 10;

(d) the possible consequences of the intended further processing for data subjects;

(e) the existence of appropriate safeguards, which may include encryption or pseudonymisation.

Data Protection Principles – Data Minimization

ART. 5(1)(C) GDPR

(c) adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed ('data minimisation');

- Processing must be **adequate**, **relevant** and **limited to what is necessary** in relation to the **purpose**.
- Cf. Recital 39: '*The personal data should be adequate, relevant and limited to what is necessary for the purposes for which they are processed. This requires, in particular, ensuring that the period for which the personal data are stored is limited to a strict minimum. Personal data should be processed* ***only if the purpose of the processing could not reasonably be fulfilled by other means.***'

Data Protection Principles – Data Accuracy

ART. 5(1)(D) GDPR

(d) accurate and, where necessary, kept up to date; every reasonable step must be taken to ensure that personal data that are inaccurate, having regard to the purposes for which they are processed, are erased or rectified without delay ('accuracy');

- Data must be **accurate** (having regard to the purposes for which they are processed), **and kept up to date** where necessary.
- Cf. Art. 16 GDPR on the right to rectification.

Data Protection Principles – Storage Limitation

ART. 5(1)(E) GDPR

(e) kept in a form which permits identification of data subjects for no longer than is necessary for the purposes for which the personal data are processed; personal data may be stored for longer periods insofar as the personal data will be processed solely for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes in accordance with Article 89(1) subject to implementation of the appropriate technical and organisational measures required by this Regulation in order to safeguard the rights and freedoms of the data subject ('storage limitation');

- Cf. Recital 39: '*The personal data should be adequate, relevant and limited to what is necessary for the purposes for which they are processed. This requires, in particular,* ***ensuring that the period for which the personal data are stored is limited to a strict minimum****. (...) In order to ensure that the personal data are not kept longer than necessary, time limits should be established by the controller for erasure or for a periodic review.*'

Data Protection Principles – Integrity & Confidentiality

ART. 5(1)(F) GDPR

(f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measures ('integrity and confidentiality').

- It is about **technical** but also **organisational** measures.
- Cf. Art. 32 GDPR (security of processing), Art. 33 GDPR (notification of a personal data breach to the supervisory authority), Art. 34 GDPR (communication of a personal data breach to the data subject).

Data Protection Principles – Accountability

ART. 5(2) GDPR

2. The controller shall be responsible for, and be able to demonstrate compliance with, paragraph 1 ('accountability').

- A 'new principle'.
- Obliges the data controller.

Sensitive Personal Data

- Article 9: **Processing of special categories of personal data**
- racial or ethnic origin,
- political opinions,
- religious or philosophical beliefs,
- trade union membership,
- Processing of genetic data, biometric data for the purpose of uniquely identifying a natural person,
- data concerning health or data concerning a natural person's sex life or sexual orientation shall be prohibited.
- *Bodil Lindquist* (CJEU, 2004): Article 8(1) of EU Directive: data concerning subject health life

Data Subject Rights under GDPR

data subject rights

- 'right to know' [information obligations]
- right of access
- right to rectification
- right to erasure
- right to restriction of processing
- right to data portability
- right to object
- specific rights related to some automated decision-making

Chapter III